

CO5 – INDUSTRY PROBLEM TASK

Answers with Output Screenshots

1. Windows Domain Network – NULL Sessions, RPC and Weak Shares

Given: 150 systems; 45% allow anonymous enumeration; 60% of those are susceptible to SMB lateral movement; each compromised system attempts 3 additional systems with 0.3 success probability.

Initial-stage compromise = $150 \times 0.45 \times 0.60 = 40.5$ systems (expected value).

Second-stage new compromises = $40.5 \times 3 \times 0.30 = 36.45$ systems.

Total expected compromised after the second stage = $40.5 + 36.45 = 76.95$ systems, approximately 77 systems.

70% of the network = $150 \times 0.70 = 105$ systems. Since $76.95 < 105$, the estimated second-stage spread does NOT exceed the 70% large-scale-compromise threshold.

Immediate priority: NULL sessions should be addressed first because anonymous enumeration is the upstream exposure that enables discovery and contributes to the initial compromise path. Weak shares should also be hardened because they facilitate lateral movement; RPC exposure should be restricted to required hosts/services.

Output screenshot:

```
SECURITY ANALYSIS - Q1
> python calculation
Initial compromised = 150 × 0.45 × 0.60
                    = 40.50 systems

Second-stage new compromises = 40.5 × 3 × 0.30
                             = 36.45 systems

Total expected = 76.95 systems
70% threshold = 105 systems
Risk conclusion: NOT > 70% in stage 2 estimate.
Priority: NULL sessions (upstream exposure).
```

2. RPC Exposure and Detection

Given: 120 total systems; 70 expose RPC; 40% are vulnerable; successful exploitation probability = 0.5; detection probability per exploitation attempt = 0.25.

Vulnerable systems = $70 \times 0.40 = 28$ systems.

Expected successful compromises = $28 \times 0.50 = 14$ systems.

Expected detection alerts = $28 \times 0.25 = 7$ alerts.

Therefore, an attacker attempting to remain stealthy faces a 25% detection probability per attempt while gaining an expected 14 compromises. Repeated exploitation can generate multiple alerts, increasing the chance of detection. From a stealth perspective, reducing noisy exploitation attempts or using alternative paths would be preferable.

Output screenshot:

SECURITY ANALYSIS - Q2

```
RPC-exposed systems = 70
Known vulnerable = 70 × 0.40 = 28
Expected successful compromises = 28 × 0.50 = 14
Expected detection alerts = 28 × 0.25 = 7
Stealth conclusion: exploitation creates a meaningful
detection risk; consider quieter alternative strategies.
```

3. Internet-Facing Linux Services and Weak File Permissions

Service vulnerability probabilities are 0.30, 0.20, 0.25 and 0.15. The services are independent.

Probability that none is vulnerable = $0.70 \times 0.80 \times 0.75 \times 0.85 = 0.3570$.

Probability that at least one is vulnerable = $1 - 0.3570 = 0.6430 = 64.30\%$.

Probability of full compromise = $0.6430 \times 0.50 = 0.3215 = 32.15\%$.

Strengthening file permissions alone would reduce the probability of the final privilege-escalation stage, but it would not remove the 64.30% chance of having at least one vulnerable exposed service. Therefore, service hardening and vulnerability reduction should be performed together with permission hardening.

Output screenshot:

SECURITY ANALYSIS - Q3

```
At least one vulnerable service:
1 - (0.7 × 0.8 × 0.75 × 0.85)
= 0.6430 = 64.30%

Full compromise = service vulnerability × weak-permission
escalation = 0.6430 × 0.50
= 0.3215 = 32.15%
File permissions alone reduce only the escalation stage.
```

4. NFS Unauthorized Access and Root Escalation

Unauthorized-access probabilities are 0.40, 0.30 and 0.20 for the three subnets; root escalation after access = 0.70.

Probability that no subnet gains unauthorized access = $0.60 \times 0.70 \times 0.80 = 0.336$.

Probability that at least one subnet gains access = $1 - 0.336 = 0.664 = 66.40\%$.

Overall probability of complete compromise = $0.664 \times 0.70 = 0.4648 = 46.48\%$.

Restricting NFS to one subnet substantially reduces exposure. If the lowest-risk subnet (0.20) is selected, complete-compromise probability becomes $0.20 \times 0.70 = 0.14 = 14\%$. This is a strong mitigation, provided that the selected subnet is the only one that genuinely requires NFS access and access controls are enforced.

Output screenshot:

SECURITY ANALYSIS - Q4

At least one subnet gains access:

$$1 - (0.6 \times 0.7 \times 0.8)$$

$$= 0.6640 = 66.40\%$$

$$\text{Complete compromise} = 0.6640 \times 0.70$$

$$= 0.4648 = 46.48\%$$

Restricting to the 0.20 subnet gives:

$$0.20 \times 0.70 = 0.14 = 14\% \text{ complete compromise.}$$

5. SQL Injection Data Extraction

Database size = 50,000 records; sensitive records = 30%; extraction rate = 500 records/second; blocking time = 40 seconds.

Records extracted before blocking = $500 \times 40 = 20,000$ records.

Percentage of total data compromised = $(20,000 / 50,000) \times 100 = 40\%$.

Estimated sensitive records exposed = $20,000 \times 0.30 = 6,000$ sensitive records.

The breach is HIGH severity because 40% of the entire database is exposed before blocking, including an estimated 6,000 sensitive records. The detection mechanism is therefore not sufficient by itself to protect critical data. Preventive controls such as parameterized queries, input validation, least privilege, and database monitoring are required so that the attack is blocked before substantial extraction occurs.

Output screenshot:

SECURITY ANALYSIS - Q5

Extraction rate = 500 records/second

Detection time = 40 seconds

Records extracted = $500 \times 40 = 20,000$

Percentage compromised = 40%

Sensitive records exposed = $20,000 \times 0.30 = 6,000$

Severity: HIGH

40-second detection window is not sufficient to protect critical data once extraction has begun.

Final Results Summary

Question	Key Numerical Result	Conclusion
Q1	40.5 initial; 36.45 second-stage; 76.95 total	Below 70% threshold; prioritize NULL sessions
Q2	14 compromises; 7 alerts	Stealth is challenged by detection risk
Q3	64.30% at least one vulnerable; 32.15% full	Harden services + file permissions
Q4	66.40% access; 46.48% complete	Restrict NFS; lowest-risk subnet gives 14%
Q5	20,000 records; 40%; 6,000 sensitive	High severity; detection alone insufficient